UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

Ingeniería en Tecnologías de la Información

PR02 — Blindando la información: gobernanza y cumplimiento

Sistema de Gestión de Seguridad de la Información conforme a ISO/IEC 27001

Aarón Emanuel González Díaz

Matrícula: 182447

16 de Octubre de 2026

Sección 01 — Alcance

1.1 Información de la organización

Organización: INTERAPAS — Organismo Intermunicipal Metropolitano de Agua Potable, Alcantarillado, Saneamiento y Servicios Conexos de los Municipios de Cerro de San Pedro, San Luis Potosí y Soledad de Graciano Sánchez

Nombre comercial: INTERAPAS

Giro: Organismo público descentralizado de carácter intermunicipal; prestación de los servicios de agua potable, alcantarillado, saneamiento y servicios conexos.

Cobertura: Zona metropolitana de San Luis Potosí: municipios de San Luis Potosí, Soledad de Graciano Sánchez, Cerro de San Pedro y Villa de Pozos (el nombre legal del organismo cita a los tres primeros; Villa de Pozos se atiende como parte del área metropolitana de servicio).

Sede: Av. de los Pintores 3, Fraccionamiento Los Filtros, C.P. 78210, San Luis Potosí, S.L.P.

Tamaño: Aproximadamente 649 empleados (clasificación de organización grande).

Datos institucionales clave

Indicador	Valor
Usuarios (contratos de servicio)	372,189 usuarios
Población atendida	Aproximadamente 1,191,921 personas (43.8% de la población del estado)
Eficiencia comercial	74% de los servicios facturados (ejercicio 2024)
Pagos procesados por la app INTERAPPAS (2024)	145,341 pagos en línea
Recibos digitales	Aproximadamente 20,000 recibos por período de facturación

Historia y creación

INTERAPAS fue creado por decreto el 13 de agosto de 1996 como organismo público descentralizado de carácter intermunicipal, con personalidad jurídica y patrimonio propios, encargado de prestar los servicios de agua potable, alcantarillado y saneamiento en la zona metropolitana de San Luis Potosí. Su naturaleza intermunicipal responde a que los municipios de San Luis Potosí, Soledad de Graciano Sánchez y Cerro de San Pedro —y, dentro del área metropolitana, Villa de Pozos— comparten las mismas fuentes de abastecimiento y la misma infraestructura hidráulica, por lo que su operación conjunta resulta más eficiente. El organismo cubre el ciclo completo del servicio: producción, conducción, potabilización, distribución, comercialización, descarga, tratamiento, alcantarillado sanitario y saneamiento. A lo largo de su historia ha enfrentado los retos de una región semiárida con fuerte estrés hídrico: sobreexplotación de acuíferos, dependencia de fuentes como el sistema El Realito, crecimiento urbano acelerado y la necesidad de modernizar su infraestructura y sus sistemas de información para mejorar la eficiencia y la atención ciudadana.

Misión

Proveer los servicios de agua potable, alcantarillado, saneamiento y servicios conexos a la población de la zona metropolitana de San Luis Potosí con calidad, suficiencia, eficiencia y responsabilidad, contribuyendo a la salud, el bienestar social y el desarrollo sustentable de la región.

Visión

Ser un organismo operador modelo a nivel nacional, reconocido por la calidad y continuidad de sus servicios, su solidez y transparencia financiera, su sustentabilidad hídrica y la confianza de la ciudadanía, apoyado en infraestructura e información seguras y confiables.

Valores

- Responsabilidad social y compromiso con la ciudadanía
- Transparencia y rendición de cuentas
- Eficiencia y mejora continua
- Sustentabilidad del recurso hídrico
- Honestidad e integridad en el servicio público

Objetivos estratégicos

- Garantizar el abastecimiento continuo y de calidad de agua potable a la zona metropolitana.
- Operar con eficiencia y sustentabilidad financiera e hídrica.
- Proteger la información de la ciudadanía usuaria (372,189 usuarios) y la integridad de su infraestructura.
- Cumplir el marco legal y regulatorio aplicable en materia de agua, transparencia y datos personales.
- Modernizar sus sistemas de información (sistema comercial, app INTERAPPAS, SIG) y fortalecer una cultura de seguridad de la información.

Los datos de constitución, sede, giro, tamaño, número de usuarios, población atendida, eficiencia y sistemas provienen de fuentes públicas (Informe de actividades 2024 de INTERAPAS, registro empresarial Dunsguide y notas de prensa, octubre 2024). La misión, la visión y los valores se expresan en los términos del propósito institucional público del organismo, dado que el Informe 2024 no los publica de forma textual.

1.2 Directorio institucional

Dirección General

Lic. Jorge Daniel Hernández Delgadillo — Director General

Licenciado en Derecho por la UASLP; designado por la Junta de Gobierno el 18 de octubre de 2024. Amplia trayectoria en el servicio público estatal y municipal (ex Síndico del Ayuntamiento de San Luis Potosí, ex Secretario General de Gobierno del Estado, ex Secretario de Gobierno municipal). Funge además como Secretario de la Junta de Gobierno del organismo.

Junta de Gobierno

Cargo	Nombre	Representación
Presidente de la Junta de Gobierno	Mtro. Enrique Francisco Galindo Ceballos	Presidente Municipal de San Luis Potosí
Vocal	Lic. Juan Manuel Navarro Muñiz	Presidente Municipal de Soledad de Graciano Sánchez
Vocal	C. Ángel de Jesús Nava Loredo	Presidente Municipal de Cerro de San Pedro
Vocal	Ing. José Gabino Manzo Castrejón	Director General de la Comisión Estatal del Agua (CEA)
Vocal	Lic. Fernando Díaz de León Hernández	Representante de usuarios comerciales y de servicios (CANACO)
Vocal	Ing. Gerardo Bocard Meraz	Representante del sector industrial
Vocal	Lic. Luis Víctor Hugo Salgado Delgadillo	Síndico del Ayuntamiento de San Luis Potosí
Vocal	Lic. Daniel Gerardo Cabrera Medina	Síndico del Ayuntamiento de Soledad de Graciano Sánchez
Vocal	C. Cecilia Nava López	Regidora del Ayuntamiento de Cerro de San Pedro

Órgano de control y Consejo Consultivo

Cargo	Nombre	Función
Titular del Órgano Interno de Control	C.P. Rafael Munguía Garduño	Vigilancia y control interno del organismo
Presidente del Consejo Consultivo	Ing. Héctor Mario Hinojosa Muñiz	Representante de usuarios domésticos de San Luis Potosí

Estructura organizacional (organigrama)

Junta de Gobierno (órgano máximo de gobierno)

- Dirección General
  - Órgano Interno de Control
  - Dirección Jurídica
  - Unidad de Transparencia
  - Unidad de Comunicación Social y Cultura del Agua
  - Unidad de Atención Social
  - Unidad de Planeación Estratégica
    - Subdirección de Calidad del Agua
    - Subdirección de Administración del Agua
  - Dirección de Comercialización
  - Dirección de Operación y Mantenimiento
  - Dirección de Construcción
  - Dirección de Fraccionamientos y Unidad de Proyectos
  - Dirección de Administración y Finanzas
    - Subdirección de Recursos Financieros
    - Subdirección de Recursos Contables
    - Subdirección de Recursos Materiales
  - **Unidad de Informática y Sistemas ◄ área del alcance del SGSI**

1.3 El proyecto: ¿qué es ISO/IEC 27001 y por qué implementarlo?

ISO/IEC 27001 es la norma internacional que especifica los requisitos para establecer, implementar, mantener y mejorar de forma continua un Sistema de Gestión de Seguridad de la Información (SGSI). Un SGSI es un marco de políticas, procesos y controles que permite a una organización gestionar de manera sistemática los riesgos sobre la confidencialidad, la integridad y la disponibilidad de su información.

Beneficios para INTERAPAS

- Protege los datos personales de los 372,189 usuarios y la información crítica del organismo.
- Reduce el riesgo de incidentes como el demostrado en la auditoría (fuga de datos, fraude en pagos, afectación al servicio).
- Fortalece la confianza de la ciudadanía y de la Junta de Gobierno en el manejo de la información.
- Facilita el cumplimiento del marco legal (protección de datos, transparencia) y es certificable internacionalmente.
- Instala una cultura de mejora continua (ciclo PDCA) que previene la repetición de incidentes.

> *La auditoría ofensiva realizada evidenció que, con una cadena de descuidos de configuración y de controles ausentes, un atacante podría pasar del portal de pago en línea hasta provocar una falla del proceso físico*

> *de bombeo. Implementar ISO/IEC 27001 convierte esos hallazgos dispersos en un sistema de gestión ordenado, con responsables, controles medibles y mejora continua: es la diferencia entre 'apagar incendios' y gobernar el riesgo de forma estructural. Por ello se propone a la Junta de Gobierno y a la Dirección General la adopción del SGSI conforme a esta norma, iniciando por la Unidad de Informática y Sistemas.*

1.4 Alcance del SGSI: dirección, área y jefatura

Dirección responsable: Dirección General de INTERAPAS

Área ejecutora: Unidad de Informática y Sistemas

Jefatura responsable del SGSI: Jefatura de la Unidad de Informática y Sistemas (responsable del SGSI)

Proceso dentro del alcance: Gestión de la seguridad de la información de los sistemas de información del organismo: el sistema comercial (padrón de 372,189 usuarios y facturación), la plataforma y app de pago INTERAPPAS, el Sistema de Información Geográfica (SIG), la plataforma de fraccionadores, los recibos digitales y la infraestructura informática de soporte.

Justificación del alcance

Se selecciona la Unidad de Informática y Sistemas, dependiente de la Dirección General, porque concentra y administra los activos de información de mayor exposición del organismo: los sistemas que tratan datos personales de la ciudadanía y los que soportan la operación comercial y técnica. El alcance inicial del SGSI se acota a este ámbito para lograr una implementación efectiva y demostrable, con la intención de extenderlo posteriormente al resto de las direcciones del organismo.

Sección 02 — Referencias normativas

La familia de normas ISO/IEC 27000 es amplia, así que aquí solo se retoman las que realmente aplican a INTERAPAS: un organismo que opera infraestructura crítica de agua (con tecnología operativa, OT) y que al mismo tiempo maneja los datos personales de cientos de miles de usuarios:

Norma	Relevancia para INTERAPAS
ISO/IEC 27000	Visión general y vocabulario del SGSI. Base conceptual y terminológica.
ISO/IEC 27001	Requisitos del Sistema de Gestión de Seguridad de la Información. Norma certificable base del proyecto.
ISO/IEC 27002	Controles de seguridad de la información. Guía de implementación de los controles del Anexo A.
ISO/IEC 27003	Guía de implementación del SGSI. Orienta el despliegue del proyecto.
ISO/IEC 27004	Monitoreo, medición, análisis y evaluación. Base de los indicadores de la Sección 09.
ISO/IEC 27005	Gestión de riesgos de seguridad de la información. Sustenta la matriz de riesgos de la Sección 06.
ISO/IEC 27031	Continuidad del negocio (TIC). Relevante por la dependencia del proceso físico de agua.
ISO/IEC 27035	Gestión de incidentes de seguridad de la información. Vincula con el Plan de Respuesta a Incidentes.
ISO/IEC 27019	Controles para la industria de servicios públicos (energía/agua). Específica para el entorno OT de INTERAPAS.
ISO/IEC 27017	Seguridad para servicios en la nube. Aplicable a la infraestructura de hospedaje (A18).

2.1 Marco legal y regulatorio aplicable

Marco legal	Motivo de aplicación
Ley General de Protección de Datos Personales en Posesión de Sujetos Obligados (LGPDPPSO)	Por tratarse de un organismo público que trata datos personales de la ciudadanía.
Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP)	Aplicable al tratamiento de datos en relaciones con terceros y proveedores.
Ley General de Transparencia y Acceso a la Información Pública	Obliga a INTERAPAS a publicar información de transparencia (A16).
Ley de Aguas Nacionales y normatividad estatal de agua potable	Marco sectorial de la operación del servicio.
Lineamientos de protección de infraestructura crítica	Aplicables al proceso físico y a la red OT (A04, A06, A20).

Sección 03 — Términos y definiciones

Antes de entrar en materia conviene aclarar algunos términos de la norma, para que la Alta Dirección tenga el mismo punto de partida al revisar la propuesta del SGSI:

Término	Definición
Activo de información	Todo elemento que tiene valor para la organización y que, por tanto, requiere protección (datos, sistemas, personas, infraestructura).
Confidencialidad	Propiedad de que la información no se pone a disposición ni se revela a individuos, entidades o procesos no autorizados.
Integridad	Propiedad de exactitud y completitud de la información y de los métodos de su procesamiento.
Disponibilidad	Propiedad de ser accesible y utilizable a demanda por una entidad autorizada.
Riesgo	Efecto de la incertidumbre sobre los objetivos; combinación de la probabilidad de un evento y sus consecuencias.
Control	Medida que modifica o reduce el riesgo (políticas, procedimientos, mecanismos técnicos u organizativos).
SGSI	Sistema de Gestión de Seguridad de la Información: parte del sistema de gestión global que establece, implementa, opera, supervisa y mejora la seguridad de la información.

Sección 04 — Contexto de la organización

Para entender qué hay que proteger, se levantó un inventario de 20 activos de información —10 internos y 10 externos— y a cada uno se le asignó una clasificación y las propiedades de seguridad que más le importan (C: confidencialidad, I: integridad, D: disponibilidad).

ID	Activo	Tipo	Descripción	Clasif.	Propietario
A01	**Padrón de usuarios (sistema comercial)**	Interno	Registro de titulares, domicilios y contratos de los 372,189 usuarios del servicio.	Confidencial (C-I)	Dirección de Comercialización
A02	**Sistema comercial de facturación y cobranza**	Interno	Saldos, recibos, consumos, módulos de pago, reversa y recuperación de cartera.	Confidencial (C-I)	Dirección de Comercialización
A03	**Expedientes y documentación administrativa/jurídica**	Interno	Trámites, aclaraciones, contratos y documentación de seguimiento de usuarios y del organismo.	Confidencial (C-I)	Dirección Jurídica / Unidad de Atención Social
A04	**Sistemas de supervisión y control de pozos y estaciones (OT)**	Interno	Supervisión y control del proceso físico de bombeo y distribución (tecnología operativa).	Restringido (I-D)	Dirección de Operación y Mantenimiento
A05	**Firmware y controladores de equipos de bombeo**	Interno	Software de control de los equipos y gateways de pozos y estaciones de bombeo.	Restringido (I-D)	Dirección de Operación y Mantenimiento
A06	**Red operativa (OT) de pozos y estaciones**	Interno	Segmento de red que interconecta los equipos de control, telemetría y supervisión del proceso.	Restringido (I-D)	Unidad de Informática y Sistemas / Operación
A07	**Código fuente y configuración de las aplicaciones**	Interno	Aplicaciones del portal, app INTERAPPAS, plataformas internas y sus artefactos de despliegue.	Confidencial (C-I)	Unidad de Informática y Sistemas
A08	**Credenciales y cuentas del personal**	Interno	Usuarios, contraseñas y roles del personal con acceso a los sistemas del organismo.	Confidencial (C-I)	Unidad de Informática y Sistemas
A09	**Padrón de proveedores y contratos**	Interno	Registro de proveedores, licitaciones, adquisiciones y vínculos contractuales vigentes.	Confidencial (C-I)	Dirección de Administración y Finanzas (Licitaciones/Adquisiciones)
A10	**Sistema de Información Geográfica (SIG) y telemetría de red**	Interno	Mapeo de pozos, zonas de servicio, red hidráulica y padrón geolocalizado; datos de telemetría.	Restringido (I-D)	Dirección de Fraccionamientos / Coord. Topografía y SIG
A11	**Portal ciudadano / sitio web público (interapas.mx)**	Externo	Sitio web institucional público: información, trámites y acceso a servicios en línea.	Público (I-D)	Unidad de Informática y Sistemas / Comunicación Social
A12	**Información pública y datos abiertos**	Externo	Indicadores, informes y conjuntos de datos publicados por el organismo.	Público (I-D)	Unidad de Planeación Estratégica / Comunicación Social

ID	Activo	Tipo	Descripción	Clasif.	Propietario
A13	**Plataforma de fraccionadores**	Externo	Tablero web con acceso por credenciales para desarrolladores externos (etapas de fraccionamientos).	Restringido (C-I)	Dirección de Fraccionamientos y Unidad de Proyectos
A14	**Plataforma y app de pago INTERAPPAS**	Externo	App móvil y plataforma de pago en línea (145,341 pagos en 2024); integra la pasarela de pago.	Confidencial (C-I)	Dirección de Comercialización / Unidad de Informática y Sistemas
A15	**Canal de reportes ciudadanos**	Externo	Reporte de fugas, incidencias y aclaraciones a través de la app INTERAPPAS y canales de atención.	Público (I-D)	Unidad de Atención Social
A16	**Portal e información de transparencia**	Externo	Documentos y obligaciones de transparencia publicadas conforme a la ley.	Público (I-D)	Unidad de Transparencia
A17	**Correo institucional, recibos digitales y comunicaciones**	Externo	Correo oficial, envío de ~20,000 recibos digitales por período y redes sociales institucionales.	Confidencial (C-I)	Unidad de Informática y Sistemas / Comunicación Social
A18	**Infraestructura de hospedaje / nube**	Externo	Servicios de hospedaje donde se despliegan el portal, la app INTERAPPAS y los servicios en línea.	Restringido (I-D)	Unidad de Informática y Sistemas
A19	**Actualizaciones del fabricante y sistemas gubernamentales externos**	Externo	Actualizaciones de firmware de equipos OT y sistemas externos (SA7, SICAF, SEVAC, DECLARAGUA).	Restringido (I-D)	Dirección de Operación / Administración y Finanzas
A20	**Ciudadanía / usuarios finales del servicio**	Externo	Población atendida (~1,191,921 personas), cuya seguridad y continuidad de servicio depende del proceso.	Público (D)	Dirección General

Sección 05 — Liderazgo

5.1 Política general de seguridad de la información

INTERAPAS, como organismo operador de infraestructura crítica hídrica, establece su compromiso con la protección de la confidencialidad, integridad y disponibilidad de la información y de los sistemas que sostienen el servicio de agua a la población. La Alta Dirección asume el liderazgo del Sistema de Gestión de Seguridad de la Información, provee los recursos necesarios, promueve una cultura de seguridad en todo el personal y terceros, y se compromete con la mejora continua del SGSI y con el cumplimiento del marco legal y regulatorio aplicable. Toda persona que accede a los activos de INTERAPAS es responsable de cumplir esta política y las políticas funcionales que de ella derivan.

5.2 Políticas funcionales

Se desarrollan 20 políticas funcionales, una por cada activo de información, integrando para cada una su estándar, directriz, procedimiento y línea base.

P01 — Protección del padrón de usuarios

Activo asociado: A01 (Padrón de usuarios (sistema comercial))

Estándar	Todo acceso a registros del padrón debe autorizarse por objeto, verificando que el usuario tenga relación legítima con el registro consultado.
Directriz	Los datos personales de la ciudadanía son el activo de mayor exposición legal; su acceso se rige por el principio de mínimo privilegio y necesidad de conocer.
Procedimiento	1) Autenticar al solicitante. 2) Validar en el servidor que el registro pertenezca al titular de la sesión. 3) Registrar en bitácora todo acceso. 4) Negar y alertar ante enumeración secuencial de identificadores.
Línea base	0 accesos a registros ajenos; control de autorización por objeto activo en el 100% de los endpoints que exponen datos del padrón; identificadores no predecibles (UUID).

P02 — Integridad de facturación y pagos

Activo asociado: A02 (Sistema comercial de facturación y cobranza)

Estándar	El monto a cobrar y los saldos deben calcularse y validarse siempre en el servidor desde la fuente de verdad, nunca a partir de datos enviados por el cliente.
Directriz	La integridad financiera es condición de confianza ciudadana; ningún valor con impacto económico puede confiarse al navegador del usuario.
Procedimiento	1) Recalcular el adeudo al confirmar el pago. 2) Ignorar cualquier monto recibido del cliente. 3) Conciliar diariamente transacciones contra saldos. 4) Alertar ante discrepancias monto-saldo.
Línea base	100% de pagos validados en servidor; 0 transacciones aceptadas con monto no conciliado; conciliación diaria completa.

P03 — Confidencialidad de expedientes administrativos

Activo asociado: A03 (Expedientes y documentación administrativa/jurídica)

Estándar	El acceso a un expediente se autoriza únicamente al titular o al personal facultado, validado por objeto en cada solicitud.
Directriz	Los expedientes contienen datos personales sensibles; su divulgación indebida vulnera la LGPDPPSO.
Procedimiento	1) Verificar pertenencia del expediente a la sesión. 2) Evitar identificadores incrementales predecibles. 3) Registrar accesos. 4) Revisar periódicamente patrones de acceso anómalos.

Línea base	0 expedientes accesibles por manipulación de parámetro; control de autorización por objeto en el 100% de las vistas de expediente.

P04 — Seguridad del HMI / SCADA de operación

Activo asociado: A04 (Sistemas de supervisión y control de pozos y estaciones (OT))

Estándar	El acceso al HMI de operación exige autenticación y autorización a nivel de aplicación, independientemente del segmento de red de origen.
Directriz	El HMI controla el proceso físico; su compromiso tiene impacto directo sobre la continuidad del servicio y la seguridad de la población.
Procedimiento	1) Exigir sesión autenticada y rol válido para toda vista operativa. 2) Aplicar autorización por activo. 3) Registrar toda acción de control. 4) Segregar funciones de consulta y de control.
Línea base	0 vistas operativas accesibles sin autenticación; roles de consulta y control segregados; bitácora de acciones al 100%.

P05 — Integridad y autenticidad del firmware OT

Activo asociado: A05 (Firmware y controladores de equipos de bombeo)

Estándar	Todo paquete de firmware debe verificar firma criptográfica del fabricante (autenticidad) y validación de rango de ingeniería de sus parámetros antes de instalarse.
Directriz	Confiar solo en la integridad (hash) sin verificar autenticidad permite instalar firmware manipulado; los parámetros de proceso requieren límites de seguridad.
Procedimiento	1) Verificar firma del fabricante. 2) Validar que los parámetros (p. ej. presión) estén dentro del rango seguro. 3) Requerir doble aprobación para cambios críticos. 4) Registrar y respaldar cada actualización.
Línea base	100% de paquetes con firma verificada; 0 instalaciones con parámetros fuera de rango de ingeniería; credenciales de actualización sin hashes obsoletos (SHA-1).

P06 — Segmentación de la red operativa (OPS-NET-20)

Activo asociado: A06 (Red operativa (OT) de pozos y estaciones)

Estándar	La frontera de confianza entre la red web y la red OT debe aplicarse por dirección IP real validada en el perímetro, nunca por encabezados HTTP controlados por el cliente.
Directriz	Una segmentación basada en datos falsificables equivale a no tener segmentación; la red OT debe aislarse con defensa en profundidad.
Procedimiento	1) Validar origen por IP real en firewall/VLAN. 2) Sobrescribir (no confiar) encabezados tipo X-Forwarded-For en el proxy. 3) Aplicar autenticación adicional dentro del segmento. 4) Monitorear tráfico entre zonas.
Línea base	0 accesos a /operations concedidos por encabezado falsificado; segmentación perimetral efectiva; monitoreo de conduit web-OT activo.

P07 — Gestión segura del código y despliegue

Activo asociado: A07 (Código fuente y configuración de las aplicaciones)

Estándar	Ningún artefacto de build, respaldo o código fuente debe quedar accesible en el document root público tras un despliegue.
Directriz	Los residuos de despliegue (zip, .bak, Dockerfile, .env) exponen la lógica interna y facilitan ataques posteriores.
Procedimiento	1) Automatizar limpieza post-release. 2) Deshabilitar listado de directorios. 3) Bloquear extensiones de respaldo (.bak,.old,.swp). 4) Revisar superficie externa periódicamente (dirsearch).

Línea base	0 artefactos de build públicos; listado de directorios deshabilitado; barrido de superficie externa mensual sin hallazgos críticos.

P08 — Gestión de credenciales y autorización

Activo asociado: A08 (Credenciales y cuentas del personal)

Estándar	Las decisiones de rol y privilegio se resuelven en el servidor contra la identidad autenticada; las contraseñas se protegen con algoritmos con sal y costo computacional.
Directriz	Confiar el rol a una cookie o usar hashes obsoletos (SHA-1) habilita escalamiento de privilegios y recuperación de credenciales.
Procedimiento	1) Resolver rol en servidor en cada solicitud. 2) Migrar hashes a bcrypt/argon2. 3) Regenerar identificador de sesión tras autenticar. 4) Aplicar MFA en cuentas privilegiadas.
Línea base	0 roles confiados al cliente; 0 credenciales con SHA-1; regeneración de sesión al 100% de los logins; MFA en cuentas administrativas.

P09 — Validación de vínculos proveedor-contrato

Activo asociado: A09 (Padrón de proveedores y contratos)

Estándar	La relación contrato-proveedor se verifica consultando explícitamente la relación registrada en base de datos, nunca por la mera existencia de ambos identificadores.
Directriz	Una validación de relación inconsistente permite legitimar vínculos contractuales inexistentes.
Procedimiento	1) Verificar relación real (join) contrato-proveedor. 2) Auditar cada validación. 3) Restringir el módulo a personal facultado. 4) Registrar accesos al padrón de proveedores.
Línea base	0 vínculos inexistentes validados como vigentes; 100% de validaciones auditadas.

P10 — Protección de la telemetría operativa

Activo asociado: A10 (Sistema de Información Geográfica (SIG) y telemetría de red)

Estándar	El servicio de telemetría exige autenticación y autorización a nivel de aplicación, aun dentro del segmento OT.
Directriz	La telemetría expone el estado del proceso físico en tiempo real; su lectura no autorizada es reconocimiento previo a un ataque.
Procedimiento	1) Exigir credenciales para consumir telemetría. 2) Aplicar autorización por activo. 3) Registrar consumidores. 4) Alertar sobre accesos anómalos.
Línea base	0 endpoints de telemetría sin autenticación; registro de consumidores al 100%.

P11 — Seguridad del portal ciudadano público

Activo asociado: A11 (Portal ciudadano / sitio web público (interapas.mx))

Estándar	Toda entrada de usuario se valida y codifica; el portal no debe exponer información interna mediante errores, respaldos o configuraciones.
Directriz	El portal es la cara pública y la principal superficie de ataque; debe minimizar la fuga de información y resistir inyección y XSS.
Procedimiento	1) Codificar salida y validar entrada. 2) Deshabilitar modo debug en producción. 3) Aplicar Content-Security-Policy. 4) Usar consultas parametrizadas.
Línea base	0 inyecciones SQL o XSS explotables; modo debug deshabilitado; CSP activa.

P12 — Gobernanza de datos abiertos

Activo asociado: A12 (Información pública y datos abiertos)

Estándar	La información publicada como datos abiertos se valida para no exponer datos personales ni metadatos internos sensibles.
Directriz	La apertura de datos no debe convertirse en un canal de fuga de información interna o personal.
Procedimiento	1) Revisar conjuntos antes de publicar. 2) Anonimizar datos personales. 3) Separar metadatos internos. 4) Versionar publicaciones.
Línea base	0 datos personales en conjuntos abiertos; revisión previa al 100% de las publicaciones.

P13 — Gestión de seguridad de terceros

Activo asociado: A13 (Plataforma de fraccionadores)

Estándar	Todo proveedor con acceso a sistemas, instalaciones o infraestructura OT se somete a evaluación de seguridad y acuerdos de confidencialidad.
Directriz	Los terceros amplían la superficie de ataque; su acceso debe gobernarse con el mismo rigor que el personal interno.
Procedimiento	1) Evaluar al proveedor antes de otorgar acceso. 2) Firmar acuerdos de confidencialidad. 3) Otorgar acceso mínimo y temporal. 4) Revocar al término del contrato.
Línea base	100% de proveedores con evaluación y acuerdo; 0 accesos activos de proveedores sin contrato vigente.

P14 — Seguridad de la pasarela de pago

Activo asociado: A14 (Plataforma y app de pago INTERAPPAS)

Estándar	La integración con la pasarela de pago cumple estándares de la industria (PCI-DSS) y no permite manipulación del monto ni exposición de datos de tarjeta.
Directriz	El procesamiento de pagos involucra datos financieros regulados; su compromiso tiene impacto económico y legal.
Procedimiento	1) Delegar el manejo de datos de tarjeta a la pasarela certificada. 2) Validar montos en servidor. 3) Cifrar la comunicación. 4) Conciliar transacciones.
Línea base	Cumplimiento PCI-DSS vigente; 0 datos de tarjeta almacenados localmente; 100% de montos validados en servidor.

P15 — Seguridad del canal de reportes ciudadanos

Activo asociado: A15 (Canal de reportes ciudadanos)

Estándar	El contenido de los reportes ciudadanos se sanitiza y codifica antes de almacenarse y mostrarse, impidiendo la ejecución de código.
Directriz	Un campo de texto libre sin sanitizar permite XSS almacenado que afecta a cualquier usuario que vea el reporte.
Procedimiento	1) Validar y codificar la entrada. 2) Limitar el formato permitido. 3) Aplicar CSP. 4) Revisar reportes con contenido sospechoso.
Línea base	0 reportes con scripts ejecutables; codificación de salida al 100%.

P16 — Gestión de información de transparencia

Activo asociado: A16 (Portal e información de transparencia)

Estándar	La información de transparencia se publica completa y oportuna, pero validada para no divulgar datos personales ni internos fuera de obligación.
Directriz	La transparencia es una obligación legal que debe equilibrarse con la protección de datos personales.

Procedimiento	1) Clasificar la información antes de publicar. 2) Testar datos personales. 3) Publicar en formatos accesibles. 4) Mantener versionado.
Línea base	100% de obligaciones de transparencia cumplidas; 0 datos personales indebidamente publicados.

P17 — Seguridad del correo y comunicaciones

Activo asociado: A17 (Correo institucional, recibos digitales y comunicaciones)

Estándar	El correo institucional usa cifrado en tránsito, autenticación de remitente (SPF/DKIM/DMARC) y controles anti-phishing.
Directriz	El correo es el principal vector de ingeniería social; su protección reduce el riesgo de compromiso de credenciales.
Procedimiento	1) Configurar SPF/DKIM/DMARC. 2) Filtrar phishing y malware. 3) Capacitar al personal. 4) Reportar y analizar incidentes.
Línea base	SPF/DKIM/DMARC activos; <5% de clics en simulacros de phishing; filtrado anti-malware al 100%.

P18 — Seguridad de la infraestructura de hospedaje

Activo asociado: A18 (Infraestructura de hospedaje / nube)

Estándar	Los entornos de hospedaje se endurecen (hardening), se mantienen actualizados y excluyen archivos de infraestructura del contenido servido.
Directriz	Una infraestructura mal configurada expone Dockerfiles, variables de entorno y servicios internos.
Procedimiento	1) Aplicar hardening de contenedores. 2) Excluir archivos de infraestructura (.dockerignore). 3) Gestionar parches. 4) Monitorear servicios expuestos.
Línea base	0 archivos de infraestructura públicos; parches críticos aplicados en <=15 días; hardening verificado.

P19 — Gestión de actualizaciones del fabricante

Activo asociado: A19 (Actualizaciones del fabricante y sistemas gubernamentales externos)

Estándar	Las actualizaciones de firmware del fabricante se verifican en autenticidad e integridad y se prueban en entorno controlado antes de producción.
Directriz	Aceptar actualizaciones sin verificar su origen permite la instalación de firmware malicioso (ATT&CK ICS T1693).
Procedimiento	1) Verificar firma del fabricante. 2) Probar en entorno aislado. 3) Aprobar formalmente. 4) Desplegar con ventana y respaldo.
Línea base	100% de actualizaciones con firma verificada y prueba previa; 0 despliegues sin aprobación formal.

P20 — Continuidad del servicio a la ciudadanía

Activo asociado: A20 (Ciudadanía / usuarios finales del servicio)

Estándar	Los parámetros de control del proceso físico cuentan con validación de rango e interlocks independientes de software que protegen la continuidad del servicio.
Directriz	La seguridad de la población depende de que ninguna manipulación de software pueda llevar el proceso a un estado catastrófico.
Procedimiento	1) Definir rangos de ingeniería por parámetro. 2) Implementar interlocks físicos/independientes. 3) Requerir doble aprobación para cambios críticos. 4) Ensayar planes de continuidad.
Línea base	100% de parámetros críticos con rango e interlock; plan de continuidad probado semestralmente; disponibilidad >=99.8%.

Sección 06 — Planificación

6.1 Matriz de riesgos (5×5)

De cada uno de los 20 activos de información se identifica una amenaza principal y se valora en una matriz de 5×5: la probabilidad (P) y el impacto (I) se califican en escala 1 (Muy baja) a 5 (Muy alta), y el nivel de riesgo se deriva de su producto P×I (Bajo 1-5, Medio 6-10, Alto 11-15, Crítico 16-25). Cada amenaza se vincula con los hallazgos reales de la auditoría ofensiva (Informe de Seguridad Ofensiva), así cada riesgo queda sustentado en evidencia real y no en una suposición. El "hecho crítico" corresponde a las amenazas de mayor probabilidad y mayor impacto (R06 — bypass de la frontera OT — en 25).

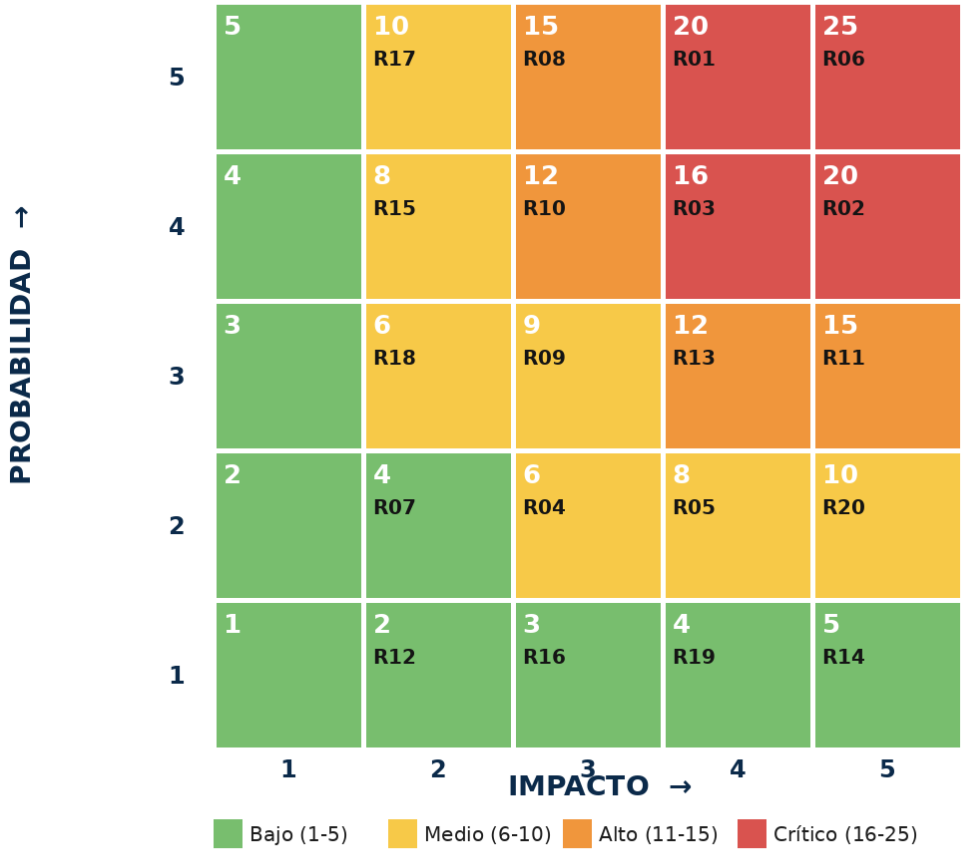


Figura 6.1 — Mapa de calor de riesgos 5×5 (probabilidad × impacto).

ID	Amenaza	Vulnerabilidad (hallazgo)	P	I	Nivel	Tratamiento
R01	Acceso no autorizado a registros del padrón (enumeración de IDs)	IDOR/BOLA en consulta de cuentas e historial (hallazgos 03, 11, 12)	5	4	**Crítico**	Mitigar
R02	Alteración del monto de pago (fraude financiero)	Monto confiado al cliente (hallazgo 13)	4	5	**Crítico**	Mitigar
R03	Divulgación de expedientes de terceros	IDOR en expediente (hallazgo 03)	4	4	**Crítico**	Mitigar

ID	Amenaza	Vulnerabilidad (hallazgo)	P	I	Nivel	Tratamiento
R04	Operación no autorizada del proceso físico vía HMI	Falta de autenticación/autorización OT (hallazgos 17, 19)	2	3	**Medio**	Mitigar
R05	Instalación de firmware manipulado	Validación solo de integridad, no de autenticidad (hallazgo 18)	2	4	**Medio**	Mitigar
R06	Bypass de la frontera de confianza hacia la red OT	Confianza en X-Forwarded-For (hallazgo 16)	5	5	**Crítico**	Mitigar
R07	Exposición de artefactos de despliegue y código	robots.txt, listado de directorios, .bak (hallazgos 01, 02, 04, 09)	2	2	**Bajo**	Mitigar
R08	Escalamiento de privilegios y robo de sesión	Cookie de rol, fijación de sesión, hash SHA-1 (hallazgos 06, 10, 18)	5	3	**Alto**	Mitigar
R09	Legitimación de vínculos contractuales inexistentes	Validación de relación inconsistente (hallazgo 14)	3	3	**Medio**	Mitigar
R10	Reconocimiento del proceso físico en tiempo real	Telemetría OT sin autenticación (hallazgo 17)	4	3	**Alto**	Mitigar
R11	Compromiso de la base de datos e inyección en el portal	Inyección SQL y errores verbosos (hallazgos 07, 05)	3	5	**Alto**	Mitigar
R12	Fuga de datos personales en datos abiertos	Exposición de información interna/personal	1	2	**Bajo**	Mitigar
R13	Compromiso a través de un tercero con acceso	Acceso de proveedores sin gobierno de seguridad	3	4	**Alto**	Mitigar
R14	Exposición o manipulación de datos de pago	Manipulación del flujo de pago (hallazgo 13)	1	5	**Bajo**	Transferir
R15	XSS almacenado que afecta a otros usuarios	Reportes sin sanitizar (hallazgo 08)	4	2	**Medio**	Mitigar
R16	Divulgación de código fuente o datos por respaldos	Archivo .bak servido como texto (hallazgo 04)	1	3	**Bajo**	Mitigar
R17	Compromiso de credenciales por phishing	Ingeniería social sobre el personal	5	2	**Medio**	Mitigar
R18	Exposición de infraestructura y servicios internos	Dockerfile/.env accesibles (hallazgo 09)	3	2	**Medio**	Mitigar
R19	Firmware malicioso del canal de actualización	Credencial legacy débil; sin verificación de autenticidad (hallazgo 18)	1	4	**Bajo**	Mitigar
R20	Falla catastrófica del proceso físico por manipulación de parámetro	Sin validación de rango de ingeniería (hallazgo 20)	2	5	**Medio**	Evitar

6.2 Administración del riesgo

La estrategia de tratamiento del riesgo en INTERAPAS se basa en cuatro opciones, seleccionadas según el nivel de cada riesgo y el apetito de riesgo de la organización:

- Mitigar: aplicar controles que reduzcan la probabilidad o el impacto (opción predominante para los riesgos Altos y Críticos técnicos).
- Transferir: trasladar el riesgo a un tercero especializado (p. ej. delegar el procesamiento de pagos a una pasarela certificada PCI-DSS — R14).
- Evitar: eliminar la exposición rediseñando el proceso (p. ej. interlocks independientes de software para impedir estados catastróficos — R20).

- Aceptar: asumir formalmente el riesgo residual cuando su nivel es bajo y el costo del control excede el beneficio, con aprobación documentada.

Los riesgos críticos (R01, R02, R03, R06) se priorizan para tratamiento inmediato (30 días) conforme al acuerdo A2 de la minuta. El riesgo residual se reevalúa en cada ciclo de revisión del SGSI.

Sección 07 — Soporte

7.1 Minuta de presentación del SGSI

Reunión	Presentación de la propuesta del SGSI (ISO/IEC 27001) a la Dirección General de INTERAPAS
Fecha	Octube 2026
Lugar	Sala de juntas, Dirección General, INTERAPAS
Convoca	Unidad de Informática y Sistemas
Objetivo	Presentar el proyecto de implementación del SGSI, acordar su alcance, responsables y recursos.

Interesados y participantes

Nombre	Cargo	Rol en el proyecto
Lic. Jorge Daniel Hernández Delgadillo	Director General	Patrocinador del proyecto
Titular de la Unidad de Informática y Sistemas	Jefe de la Unidad de Informática y Sistemas	Responsable técnico del SGSI
Titular de la Dirección de Comercialización	Director de Comercialización	Propietario del padrón y la facturación
Titular de la Dirección de Operación y Mantenimiento	Director de Operación y Mantenimiento	Enlace de tecnología operativa (OT)
C.P. Rafael Munguía Garduño	Titular del Órgano Interno de Control	Vigilancia y control interno
Titular de la Unidad de Transparencia	Unidad de Transparencia	Enlace jurídico y de datos personales
Aarón E. González Díaz	Autor de la propuesta (estudiante, UPSLP)	Responsable propuesto del SGSI

Orden del día

1. Presentación de los resultados de la auditoría ofensiva (20 vulnerabilidades).

2. Propuesta de implementación del SGSI conforme a ISO/IEC 27001.

3. Alcance, activos de información y políticas funcionales.

4. Matriz de riesgos y estrategia de tratamiento.

5. Roles y responsabilidades (RACI) y recursos requeridos.

Acuerdos

- A1. La Dirección General aprueba el inicio formal del proyecto de implementación del SGSI y designa a la Unidad de Informática y Sistemas como responsable.
- A2. Se prioriza la mitigación de los riesgos críticos R01, R02, R03 y R06 en un plazo de 30 días.
- A3. Se asignará presupuesto para herramientas de monitoreo, MFA y la migración de credenciales a bcrypt/argon2.
- A4. Se instituye un comité de seguridad de la información con reuniones mensuales de seguimiento.
- A5. Se desarrollará el soporte documental de prevención (flyer, presentación, curso y video) y se capacitará al 100% del personal.

Áreas de oportunidad identificadas

- O1. Ausencia de segmentación de red real entre la zona web y la zona OT.
- O2. Controles de autorización inconsistentes a nivel de objeto en el portal.
- O3. Credenciales con algoritmos obsoletos y sin MFA.
- O4. Falta de verificación de autenticidad y validación de rango en el canal de firmware.
- O5. Cultura de seguridad incipiente; se requiere capacitación y concientización.

Firmas de conformidad

Los participantes manifiestan su conformidad con los acuerdos asentados en esta minuta:

_____
Lic. Jorge Daniel Hernández Delgadillo
Director General

_____
Titular de la Unidad de Informática y Sistemas
Jefe de la Unidad de Informática y Sistemas

_____
Titular de la Dirección de Comercialización
Director de Comercialización

_____
Titular de la Dirección de Operación y Mantenimiento
Director de Operación y Mantenimiento

_____
C.P. Rafael Munguía Garduño
Titular del Órgano Interno de Control

_____
Titular de la Unidad de Transparencia
Unidad de Transparencia

_____
Aarón E. González Díaz
Autor de la propuesta (estudiante, UPSLP)

7.2 Soporte documental de prevención

A partir de las amenazas identificadas en la matriz de riesgos, se elabora el siguiente soporte de prevención y concientización dirigido al personal y a la ciudadanía.

7.2.1 Flyer de concientización

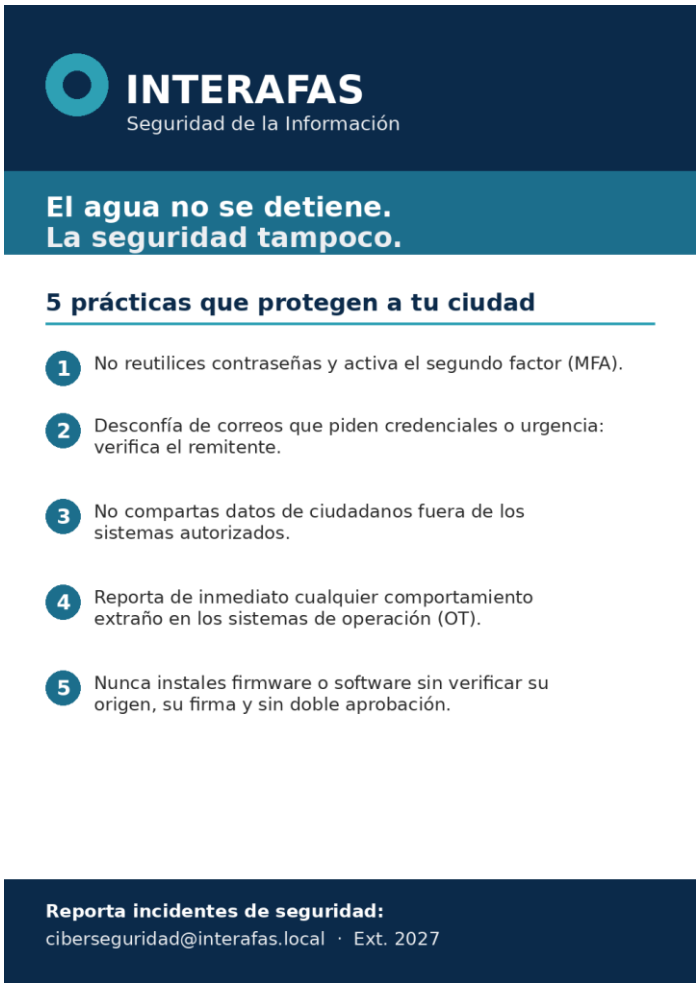


Figura 7.1 — Flyer de concientización en seguridad de la información.

7.2.2 Curso de concientización

Nombre: Curso de concientización: Fundamentos de seguridad de la información en INTERAPAS

Duración: 4 horas (2 sesiones de 2 h) · modalidad mixta

- Módulo 1 — Por qué la seguridad protege el agua: de un error web a una falla de planta (caso INTERAPAS-LAB).
- Módulo 2 — Datos personales de la ciudadanía: confidencialidad, mínimo privilegio y marco legal.
- Módulo 3 — Contraseñas, sesiones y MFA: higiene de credenciales.
- Módulo 4 — Phishing e ingeniería social: cómo reconocer y reportar.
- Módulo 5 — Seguridad en la zona OT: segmentación, firmware y parámetros de proceso.
- Módulo 6 — Qué hacer ante un incidente: roles y reporte.

Evaluación: Cuestionario de 10 reactivos; aprobación >=80%; simulacro de phishing posterior.

7.2.3 Presentación ejecutiva

Nombre: Presentación ejecutiva: El SGSI de INTERAPAS

- 1. Portada — El SGSI de INTERAPAS.

- 2. El problema: 20 vulnerabilidades y una falla catastrófica simulada.
- 3. La cadena de ataque: del sitio web a la planta.
- 4. Qué es un SGSI y por qué ISO 27001.
- 5. Activos de información críticos de INTERAPAS.
- 6. Los riesgos y su tratamiento.
- 7. Las 20 políticas funcionales.
- 8. Roles y responsabilidades (RACI).
- 9. El compromiso de todos: cultura de seguridad.
- 10. Cierre y llamado a la acción.

7.2.4 Video de concientización (guion)

Nombre: Video de concientización (guion, 90 segundos)

- ESC 1 (0-15s) — Imagen de la ciudad con agua corriendo. Voz: 'Cada gota que llega a tu hogar depende de sistemas que debemos proteger.'
- ESC 2 (15-40s) — Animación de un atacante que entra por un descuido del sitio web. Voz: 'Un pequeño error puede abrir la puerta a toda la operación.'
- ESC 3 (40-65s) — Montaje de buenas prácticas (MFA, reportar phishing, verificar firmware). Voz: 'Tu atención es la primera defensa.'
- ESC 4 (65-90s) — Logo INTERAPAS y cierre. Voz: 'El agua no se detiene. La seguridad tampoco. Protege la información, protege a tu ciudad.'

Sección 08 — Operación

8.1 Matriz RACI

La matriz RACI define, para cada actividad del SGSI, quién es Responsable (R) de ejecutarla, quién rinde cuentas o Aprueba (A), quién es Consultado (C) y quién es Informado (I).

Actividad	Dir. General	Dir. TI	Subdir. Ciberseg. (SGSI)	Dir. Operación OT	Dir. Admón/Finanzas	Personal / Usuarios
Aprobar y patrocinar el SGSI	**A**	**R**	**C**	**C**	**C**	**I**
Definir políticas funcionales	**I**	**A**	**R**	**C**	**C**	**I**
Ejecutar la matriz de riesgos	**I**	**A**	**R**	**C**	**C**	**I**
Implementar controles técnicos	**I**	**A**	**R**	**C**	**I**	**I**
Operar y mantener la zona OT de forma segura	**I**	**C**	**C**	**R**	**I**	**I**
Gestionar accesos y credenciales	**I**	**A**	**R**	**C**	**C**	**I**
Capacitar y concientizar al personal	**I**	**A**	**R**	**C**	**C**	**R**
Monitorear y evaluar el desempeño (checklists)	**I**	**A**	**R**	**C**	**C**	**I**
Responder a incidentes de seguridad	**I**	**A**	**R**	**R**	**C**	**I**
Aplicar las mejoras del ciclo PDCA	**A**	**R**	**R**	**C**	**C**	**I**

R = Responsable · A = Aprueba / rinde cuentas · C = Consultado · I = Informado

Sección 09 — Evaluación del desempeño

Una vez puesto en marcha el SGSI, se revisó con una lista de verificación qué tanto se estaba cumpliendo en la práctica. El resultado es el que normalmente se obtiene en una primera implementación: no todo salió perfecto. Cada control se califica como Cumple, Cumple parcialmente o No cumple.

Política	Ítem verificado	Estado	Observación
P01	Autorización por objeto en endpoints del padrón	**Cumple**	Implementado y verificado en el 100% de los endpoints del padrón.
P02	Recalculo de montos en servidor	**Cumple**	Los montos se recalculan y concilian diariamente.
P03	Validación de pertenencia de expediente	**Cumple**	Identificadores opacos desplegados.
P04	Autenticación y autorización en el HMI	**Cumple parcial**	Autenticación implementada; falta segregar completamente consulta y control.
P05	Firma criptográfica y validación de rango en firmware	**No cumple**	Se implementó la validación de rango, pero la verificación de firma del fabricante NO quedó operativa por falta del certificado del proveedor.
P06	Segmentación perimetral de la red OT	**Cumple parcial**	El proxy ya sobrescribe X-Forwarded-For; falta completar la segmentación física por VLAN.
P07	Limpieza de artefactos de despliegue	**Cumple**	Automatizada en el pipeline; barrido mensual sin hallazgos.
P08	Rol en servidor, MFA y migración de hashes	**Cumple parcial**	Rol en servidor y bcrypt desplegados; MFA pendiente en cuentas de operación OT.
P09	Verificación de relación proveedor-contrato	**Cumple**	Join real en BD; validaciones auditadas.
P10	Autenticación del servicio de telemetría	**Cumple**	Telemetría protegida por autenticación.
P11	Consultas parametrizadas y CSP en el portal	**Cumple**	Sin inyecciones ni XSS en pruebas de regresión.
P12	Anonimización en datos abiertos	**Cumple**	Revisión previa activa.
P13	Evaluación y NDA de proveedores	**Cumple parcial**	NDA al 100%; evaluación de seguridad pendiente para 12 proveedores heredados.
P14	Cumplimiento PCI-DSS de la pasarela	**Cumple**	Delegado a pasarela certificada.
P15	Sanitización del canal de reportes	**Cumple**	Codificación de salida verificada.
P16	Clasificación previa de transparencia	**Cumple**	Sin datos personales publicados.
P17	SPF/DKIM/DMARC y antiphishing	**Cumple parcial**	SPF/DKIM activos; DMARC en modo monitoreo, aún no en rechazo.
P18	Hardening y exclusión de archivos de infraestructura	**Cumple**	Verificado.
P19	Verificación y prueba de actualizaciones del fabricante	**No cumple**	Depende del mismo certificado ausente que P05; las actualizaciones aún no se verifican en autenticidad.
P20	Validación de rango e interlocks del proceso	**Cumple parcial**	Validación de rango en software desplegada; interlocks independientes de hardware aún en adquisición.

Resultado global: **12 controles Cumplen**, **6 Cumplen parcialmente** y **2 No cumplen** (de 20 verificados).
Los controles P05 (integridad y autenticidad del firmware) y P19 (gestión de actualizaciones del fabricante) no lograron su objetivo y se canalizan a la fase de mejora (Sección 10).

Sección 10 — Mejora

10.1 Diagnóstico a partir del checklist de auditoría

La evaluación del desempeño (Sección 09) mostró que el SGSI se implementó con un nivel de madurez aceptable: de 20 controles verificados, 12 cumplen plenamente, 6 cumplen parcialmente y 2 no cumplen. Los dos controles que NO lograron su objetivo son P05 (integridad y autenticidad del firmware OT) y P19 (gestión de actualizaciones del fabricante), ambos bloqueados por la misma causa raíz: la ausencia del certificado del fabricante necesario para verificar criptográficamente la autenticidad de los paquetes de firmware. Dado que estos controles protegen directamente contra el escenario de mayor severidad del proyecto (hallazgos 18 y 20, manipulación de firmware y falla catastrófica del proceso), se priorizan para el rediseño del ciclo de mejora PDCA (fase Act).

10.2 Rediseño de la política funcional que no logró su objetivo

P05 — Integridad y autenticidad del firmware OT (rediseñada)

Causa raíz del incumplimiento: El control no se pudo verificar porque la organización carecía del certificado público del fabricante y de un procedimiento formal para gestionarlo; además, la autenticidad dependía de un único punto (el canal de actualización) sin control compensatorio.

Cambios introducidos

- Se incorpora un procedimiento formal de gestión del certificado del fabricante (solicitud, custodia, renovación y revocación), con responsable y SLA definidos.
- Mientras se obtiene el certificado, se establece un control compensatorio: toda actualización de firmware requiere doble aprobación humana y validación manual del hash contra el canal oficial del fabricante, en un entorno aislado, antes de producción.
- Se añade la validación de rango de ingeniería como control independiente del de autenticidad, de modo que aunque falle la verificación de firma, ningún parámetro fuera de rango pueda instalarse.
- Se define un indicador específico: 0 actualizaciones en producción sin firma verificada O sin la doble aprobación del control compensatorio.

Nueva línea base: 100% de actualizaciones con firma verificada o, en su defecto, con control compensatorio (doble aprobación + validación manual en entorno aislado); 0 parámetros fuera de rango; certificado del fabricante gestionado con responsable y fecha de renovación.

10.3 Rediseño del soporte de prevención

- Se agrega al curso un módulo específico y obligatorio sobre gestión segura de firmware y verificación de autenticidad (dirigido al personal de Mantenimiento OT), pues los controles que fallaron son de ese ámbito.
- El flyer se actualiza con un mensaje directo sobre firmware: 'Nunca instales firmware sin verificar su firma y sin la doble aprobación', reforzando la práctica del control compensatorio.
- La presentación ejecutiva incorpora una lámina de seguimiento del ciclo PDCA que muestra los controles parciales y no cumplidos y su plan de cierre, para mantener la atención de la Alta Dirección.
- Se programa un simulacro de recepción de una actualización de firmware no autorizada, para medir si el personal aplica correctamente el procedimiento compensatorio.

10.4 Plan de cierre de los controles parciales

Control	Acción de mejora
P04 — HMI	Completar la segregación de funciones de consulta y control (perfiles separados).
P06 — Segmentación OT	Finalizar la segmentación física por VLAN además de la sobrescritura de encabezados.
P08 — Credenciales	Desplegar MFA en las cuentas de operación OT pendientes.
P13 — Terceros	Completar la evaluación de seguridad de los 12 proveedores heredados.
P17 — Correo	Pasar DMARC de modo monitoreo a modo rechazo.
P20 — Continuidad	Concluir la adquisición e instalación de los interlocks independientes de hardware.

Con estas acciones, el SGSI de INTERAPAS completa el ciclo de mejora continua (PDCA): planificar (Secciones 04-06), hacer (Sección 07-08), verificar (Sección 09) y actuar (Sección 10), quedando listo para un nuevo ciclo de evaluación.